Khoa Công nghệ Thông tin (FIT) - Trường Đại học Khoa học Tự nhiên (HCMUS)

CS423 / CSC15003 - Kiểm chứng Phần mềm (AI-augmented, 2026)

CHÍNH SÁCH AI, BIỂU MẪU - 2026 v1.0

Biểu mẫu Khai báo Sử dụng AI

Đính kèm cho mọi bài tập có dùng AI ở bất kỳ mức nào.

Tài liệu được biên soạn lại từ Med Kharbach, PhD (2026) - Mẫu Chính sách Sử dụng AI cho Giáo dục Đại học. Giấy phép CC BY-NC-SA 4.0. Phiên bản này được FIT@HCMUS điều chỉnh cho môn CS423 / CSC15003 Kiểm chứng Phần mềm.

1. Thông tin Môn học & Sinh viên

Mục	Giá trị
Môn học:	CS423 / CSC13003 - Kiểm chứng Phần mềm
Mã bài tập:	HW02-AI
Tên bài tập:	Domain Testing on EShop
Cấp độ AI (1-5):	Cấp 2, 3, 4; Bloom-AI G9.2 Apply / G9.3 Analyse
Ngày:	20/10/2026
Họ tên sinh viên:	Tống Dương Thái Hòa
MSSV:	23120262

2. Câu hỏi Khai báo

1. Công cụ AI đã dùng:

Liệt kê mọi công cụ AI dùng cho bài tập này (ví dụ AI Tool (e.g., ChatGPT, Claude, Gemini), ChatGPT, GitHub Copilot, Cursor, Gemini).

OpenAI Codex (transcript kỹ thuật tại Appendix A); Antigravity IDE / Claude Sonnet (công cụ được khai trong bản sinh viên cung cấp; không có transcript Claude riêng trong log Codex).

2. Giai đoạn nào của bài tập có dùng AI:

Tick tất cả: [ ] brainstorm [ ] outline [ ] viết nháp [ ] phản hồi [ ] sửa chữa [ ] code [ ] phân tích dữ liệu [ ] thiết kế đồ hoạ [ ] khác (ghi rõ).

[x] brainstorm [x] outline [x] viết nháp [x] phản hồi [x] sửa chữa [x] code [x] phân tích dữ liệu [ ] thiết kế đồ hoạ [x] khác: đối chiếu bằng chứng, soạn Issue và xuất tài liệu.

3. Prompt / nhiệm vụ chính cho AI:

Dán nguyên văn 2-3 prompt quan trọng nhất. Để xem đầy đủ, đính kèm Phụ lục A (prompt_log.md).

OpenAI Codex, 2026-10-19T19:48:53.386Z; LOG-035.

> [@mattpocock-skills](plugin://mattpocock-skills@mattpocock) Hãy viết lại thật đầy đủ, chi tiết cho từng loại, bugs có thể chia thành từng id cho từng file luôn hoặc chung 1 file theo domain tùy bạn. Sau khi viết lại toàn bộ thì kiểm tra lại tất cả và so sánh với yêu cầu của đề bài xem còn thiếu sót gì nữa không? Video thì cứ cho link temp vậy đi, vì tôi đang quay, đảm bảo có nên cứ đặt đó và tui sẽ tự đặt link vào sau.

OpenAI Codex, 2026-10-20T05:18:31.278Z; LOG-072.

> Phần skills [domain-bva-testing](hw02/software-testing-hw02-domain-testing/.agents/skills/domain-bva-testing/) , hãy đi search những skills ở https://skills.sh/ và tham khảo từ
> https://github.com/affaan-m/ECC
> https://github.com/mrgoonie/claudekit-skills
> https://github.com/mattpocock/skills
> https://github.com/MengTo/Skills
> https://github.com/agentskills/agentskills
> https://github.com/addyosmani/agent-skills
> https://github.com/obra/superpowers
> Dùng cả [$find-skills]([local path omitted]
> Viết thì đừng aim vào eshop sut, hãy làm nó global vì có thể dùng cho mọi nơi mà?
> Còn mấy cái scripts, data, refenreces, agents/openai.yaml,.... đầy đủ vào chứ

OpenAI Codex, 2026-10-20T07:19:12.231Z; LOG-087.

> Complete hết toàn bộ đi rồi hẳn commit (chờ tui review trước). Lần này là hoàn thiện luôn final để nộp đó nhé. Tui đã xóa tất cả issues của bản thân cũ trên github. Vì tạo theo từng bugs luôn chứ không phải lớn, format phải chuẩn issues quốc tế nữa chứ? Giờ cần kiểm tra đầy đủ rồi mới đẩy lên từng cái chi tiết và rõ ràng, và những issues cũ cũng chứa mấy cái không liên quan ví dụ path nằm trong workspace cá nhân?
> Bạn có thể chụp màn hình mà không dùng computer use được không? Ví dụ Playwright CLI chẳng hạn, để tránh tốn quá nhiều token.
> Tìm ra một số bugs mới, hãy fill đầy đủ và screenshot đầy đủ vào minh chứng.
> 2. Bug mới
> BUG-A04 - API hồ sơ làm lộ mật khẩu và reset token
> Request
> GET /api/users/me
> Authorization: Bearer <JWT user>
> Actual
> {
> "id": 2,
> "name": "Test User",
> "email": "test@eshop.com",
> "password": "Test1234!",
> "role": "user",
> "reset_token": null,
> "shipping_address": "1 Test Street",
> "phone": "0912345678"
> }
> Sau khi gọi POST /api/forgot-password, GET /api/users/me trả tiếp:
> { "reset_token": "2345" }
> Expected: response hồ sơ chỉ chứa các field cần thiết; không bao giờ trả password hay reset_token.
> Oracle: SEC-01 (mật khẩu không lưu plaintext), SEC-02, nguyên tắc least privilege của FR-04.
> Root cause: backend/server.js:112-115 dùng SELECT * FROM users rồi res.json(user). POST /api/login cũng trả nguyên object user gồm password (server.js:35,52).
> Impact: bất kỳ ai có JWT (XSS, máy dùng chung, log) đều đọc được mật khẩu plaintext và reset token còn hiệu lực → chiếm tài khoản, đặc biệt nguy hiểm nếu user dùng lại mật khẩu.

Fix: projection cột cụ thể; loại password, reset_token khỏi mọi response; hash password; không trả token reset qua profile.
BUG-A05 - Mobile cập nhật hồ sơ làm mất địa chỉ giao hàng
Mobile gửi (frontend-mobile/App.js:302):

```
{
  "name": "Mobile User",
  "phone": "0912345678",
  "shippingAddress": "Mobile Address"
}
```

Backend chỉ đọc shipping_address (backend/server.js:119), nên shippingAddress bị bỏ qua.
Actual đã reproduce bằng đúng payload trên:
PUT /api/users/me → 200 {"message":"Profile updated"}

```
GET /api/users/me → {
  "name": "Mobile User",
  "phone": "0912345678",
  "shipping_address": null
}
```

Expected: địa chỉ mới được lưu đúng. Oracle: FR-04 “cập nhật ... Địa chỉ giao hàng mặc định”.
Impact: mỗi lần lưu hồ sơ trên mobile, địa chỉ mặc định bị xóa âm thầm. UI vẫn báo “Cập nhật thành công!” và còn cập nhật state local (App.js:305-306), nên người dùng không biết dữ liệu đã mất.
Fix: gửi shipping_address thay vì shippingAddress; backend nên whitelist field và xử lý partial update đúng cách.
BUG-A06 - Mobile từ chối phone hợp lệ, chấp nhận prefix sai
frontend-mobile/App.js:287 dùng cùng regex sai như Web:
/^[1-9][0-9]{8,9}$/
Kết quả đánh giá regex:

Input	Kết quả	Theo SRS
0912345678	❌ reject	✅ valid (10 số, bắt đầu 0)
09123456789	❌ reject	✅ valid (11 số, bắt đầu 0)
1912345678	✅ accept	❌ invalid (không bắt đầu 0)
091234567	❌ reject	❌ invalid
091234567890	❌ reject	❌ invalid

Đây là cùng behavior với BUG-A03 nhưng ở client Mobile, file và bản fix khác. Chưa chạy trên thiết bị; kết luận từ source + evaluation regex, không có ảnh UI mobile.
Fix: thống nhất regex /^0\d{9,10}$/ cho cả Web và Mobile.
3. Bug cũ - xác nhận lại
BUG-A01: backend vẫn nhận phone sai.
PUT /api/users/me {"phone":"091234567"} → 200
GET /api/users/me → "phone":"091234567"
BUG-A02: không chỉ đổi được role trong DB, mà còn leo quyền thật:
PUT role=admin → GET role=admin
POST /api/login → JWT có "role":"admin"
GET /api/admin/users với token mới → 200
Đây là impact mạnh hơn mức “chưa chạy chuỗi đăng nhập lại” ghi trong BUG-A02 cũ.
BUG-A03: Web vẫn dùng /^[1-9][0-9]{8,9}$/ (Profile.jsx:43), từ chối 0912345678 và 09123456789, chấp nhận 1912345678.
4. Điểm cần oracle / observation

#	Quan sát	Đánh giá
O1	PUT {"name":"Only Name"} → 200, phone và shipping_address thành null	SRS không nói rõ partial update hay full replace. Đây là data-loss risk, cần rule trước khi chấm FAIL. Đồng thời là cơ chế khiến A05 nguy hiểm.
O2	Web Checkout và Mobile Checkout không gửi shipping_address; đơn hàng lưu null	FR-04 gọi đây là “địa chỉ giao hàng mặc định”, nhưng FR-08 không nói rõ checkout phải dùng địa chỉ này. Cần xác nhận cross-feature.
O3	Sau khi lưu profile, AuthContext không cập nhật user; rời trang rồi quay lại có thể thấy dữ liệu cũ	Source-verified (AuthContext.jsx:10-24, Profile.jsx:48-60), chưa chạy UI để kết luận FAIL.
O4	Profile.jsx:119-124 dùng type="text" cho email, trong khi FR-22 yêu cầu type="email"	Vi phạm UI requirement rõ ràng nhưng severity thấp (field disabled).
O5	POST /api/forgot-password sinh token 4 chữ số (server.js:72), trong khi FR-03 yêu cầu OTP 6 chữ số	Ngoài FR-04, nhưng làm A04 nguy hiểm hơn.

5. Thứ tự ưu tiên sửa
1. A04 - bỏ password/reset_token khỏi response, hash password.
2. A02 - whitelist name, phone, shipping_address; cấm ghi role.

```
3. A05 - sửa shippingAddress → shipping_address.
4. A01 + A03 + A06 - validate phone backend và thống nhất regex hai client.
5. O1 - quyết định partial update; nếu partial, dùng COALESCE/dynamic SET, không gán NULL cho field vắng mặt.

Có thể tìm lại những feature khác xem còn bugs không?
```

Bản hiển thị chuẩn hóa dấu câu và redaction đường dẫn máy; Appendix A ghi timestamp và digest nguồn. Đây là log kỹ thuật chọn lọc theo yêu cầu lọc hội thoại, không phải transcript toàn bộ.

4. Phần cụ thể AI đóng góp:

Càng cụ thể càng tốt. Ví dụ: 'AI sinh TC01-TC15 ở Mục 3.2; tôi viết lại TC04 và TC11; AI KHÔNG đóng góp vào Mục 1, 2, 4, hoặc AI Critique.'

AI hỗ trợ phân tích bốn feature, 132 test cases, 64 bug reports, báo cáo, reusable skill, harness bên ngoài gói nộp, thực thi API/browser/handler và kiểm tra liên kết/số liệu. Bộ ảnh gồm 71 ảnh giao diện gốc do sinh viên cung cấp và 54 ảnh mở rộng do Playwright chụp, có phân biệt live UI với recorded-execution viewer. Ảnh trang Issue được chụp riêng. Video và ảnh native do sinh viên cung cấp; không tuyên bố AI thực hiện native Mobile mới. Việc hiệu chỉnh bốn biểu mẫu và đoạn critique cũng có AI hỗ trợ.

5. Cách tôi rà soát / chỉnh sửa / xác minh đầu ra AI:

Mô tả phương pháp xác minh (chạy test, kiểm tra spec, hỏi TA, tra RFC, đối chiếu ISTQB syllabus, v.v.).

Oracle được đối chiếu với SRS baseline, ISTQB CTFL 4.2.1-4.2.2 và OWASP API3 cho response minimization. HTTP readback, marker DOM, source hashes và ảnh thật được dùng xác minh kết luận. Tổng hợp giữ 56 PASS / 70 FAIL / 6 OBSERVATION; source-handler không đổi thành native UI. Các điều kiện chưa đặc tả giữ OBSERVATION. 64 Issue được readback sau upload; đường dẫn workspace riêng không nằm trong nội dung công khai.

6. Trích dẫn (nếu môn yêu cầu):

Môn Kiểm chứng Phần mềm dùng phong cách IEEE. Ví dụ: Anthropic. (2026). AI Tool (e.g., ChatGPT, Claude, Gemini) [Large language model]. https://claude.ai

[1] OpenAI, Codex, AI coding assistant, 2026. Prompt/output log.

[2] Anthropic, Claude Sonnet, large language model, khai báo công cụ theo bản sinh viên cung cấp.

[3] ISTQB, CTFL Syllabus v4.0.1, mục 4.2.1-4.2.2. SRS baseline.

3. Cam đoan Trung thực

Bằng việc ký tên dưới đây, tôi cam đoan thông tin khai báo ở trên là chính xác và đầy đủ. Tôi hiểu rằng việc không khai báo hoặc khai báo sai lệch về việc dùng AI sẽ bị coi là vi phạm liêm chính học thuật và có thể dẫn đến điểm 0 cho bài tập cùng việc bị chuyển lên hội đồng kỷ luật.

Chữ ký

Họ tên sinh viên (in hoa):	**TỐNG DƯƠNG THÁI HÒA**
MSSV:	23120262

Họ tên sinh viên (in hoa):	**TỐNG DƯƠNG THÁI HÒA**
Lớp / Khoá:	Software Testing - CQ2023/3
Môn học:	CS423 / CSC13003 - Kiểm chứng Phần mềm
Giảng viên:	Dr. Lam Quang Vu / Dr. Tran Duy Hoang / MSc. Tran Thi Bich Hanh / MSc. Truong Phuoc Loc / MSc. Ho Tuan Thanh
Ngày:	20/10/2026
Chữ ký:	

Tham khảo

- Kharbach, M. (2026). AI Use Policy Templates for Higher Education. CC BY-NC-SA 4.0.
- ISTQB Foundation Level Syllabus (latest version).
- Hardman, P. (2025). A Post-AI Learning Taxonomy.
- Fuster Rabella, M. (2025). OECD Education Working Paper No. 338.
- Perkins, M., Roe, J., & Furze, L. (2025). AI Assessment Scale.
- Anthropic (2025). Building reliable AI test agents - engineering blog.
- DeepEval & Promptfoo documentation - testing frameworks for LLM systems.